VAPT project report

Juice Shop · generated 07 Oct 2026 14:23 UTC by VAPT Management Dashboard 0.4.0. All figures are calculated from the application database at the time of export.

Project information

Project	Juice Shop
Application	OWASP Juice Shop
Environment	Development
Application URL	*Not set*
Owner	*Not set*
Status	Active
Description	*Not set*

Executive summary

This report covers project **Juice Shop** (OWASP Juice Shop, Development).

It is based on 2 successfully processed scan(s) dated 07 Oct 2026 10:05 UTC to 07 Oct 2026 10:06 UTC; the latest is “zap-baseline.json” (OWASP ZAP).

48 unique finding(s) are recorded: 9 Medium, 17 Low, 22 Informational.

48 are active (Open, In Progress or Reopened), including 0 Critical or High. 0 are Resolved or Closed and 0 are Accepted Risk or False Positive.

Risk summary

Unique findings by severity and workflow status.

Severity	Open	In Progress	Resolved	Reopened	Accepted Risk	False Positive	Closed	Total
Critical								**0**
High								**0**
Medium	9							**9**
Low	17							**17**
Informational	22							**22**

Severity distribution



Findings by severity

Critical findings (0)

Title	Status	Endpoint	Assigned to	First detected
No Critical findings.				

High findings (0)

Title	Status	Endpoint	Assigned to	First detected
No High findings.				

Medium findings (9)

Title	Status	Endpoint	Assigned to	First detected
Cross-Domain Misconfiguration	Open	http://juice:3000/styles.css	Unassigned	07 Oct 2026 10:06 UTC
Cross-Domain Misconfiguration	Open	http://juice:3000/sitemap.xml	Unassigned	07 Oct 2026 10:06 UTC
Cross-Domain Misconfiguration	Open	http://juice:3000/robots.txt	Unassigned	07 Oct 2026 10:06 UTC
Cross-Domain Misconfiguration	Open	http://juice:3000/assets/public/favicon_js.ico	Unassigned	07 Oct 2026 10:06 UTC
Cross-Domain Misconfiguration	Open	http://juice:3000/	Unassigned	07 Oct 2026 10:06 UTC
Content Security Policy (CSP) Header Not Set	Open	http://juice:3000/sitemap.xml	Unassigned	07 Oct 2026 10:06 UTC
Content Security Policy (CSP) Header Not Set	Open	http://juice:3000/ftp/package.json.bak	Unassigned	07 Oct 2026 10:06 UTC
Content Security Policy (CSP) Header Not Set	Open	http://juice:3000/ftp	Unassigned	07 Oct 2026 10:06 UTC
Content Security Policy (CSP) Header Not Set	Open	http://juice:3000/	Unassigned	07 Oct 2026 10:06 UTC

Low findings (17)

Title	Status	Endpoint	Assigned to	First detected
Timestamp Disclosure - Unix	Open	http://juice:3000/styles.css	Unassigned	07 Oct 2026 10:06 UTC
Timestamp Disclosure - Unix	Open	http://juice:3000/sitemap.xml	Unassigned	07 Oct 2026 10:06 UTC
Timestamp Disclosure - Unix	Open	http://juice:3000/	Unassigned	07 Oct 2026 10:06 UTC

Title	Status	Endpoint	Assigned to	First detected
Deprecated Feature Policy Header Set	Open	http://juice:3000/sitemap.xml	Unassigned	07 Oct 2026 10:06 UTC
Deprecated Feature Policy Header Set	Open	http://juice:3000/scripts.js	Unassigned	07 Oct 2026 10:06 UTC
Deprecated Feature Policy Header Set	Open	http://juice:3000/polyfills.js	Unassigned	07 Oct 2026 10:06 UTC
Deprecated Feature Policy Header Set	Open	http://juice:3000/main.js	Unassigned	07 Oct 2026 10:06 UTC
Deprecated Feature Policy Header Set	Open	http://juice:3000/	Unassigned	07 Oct 2026 10:06 UTC
Dangerous JS Functions	Open	http://juice:3000/main.js	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Opener-Policy Header Missing or Invalid	Open	http://juice:3000/sitemap.xml	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Opener-Policy Header Missing or Invalid	Open	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Opener-Policy Header Missing or Invalid	Open	http://juice:3000/ftp	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Opener-Policy Header Missing or Invalid	Open	http://juice:3000/	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Embedder-Policy Header Missing or Invalid	Open	http://juice:3000/sitemap.xml	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Embedder-Policy Header Missing or Invalid	Open	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Embedder-Policy Header Missing or Invalid	Open	http://juice:3000/ftp	Unassigned	07 Oct 2026 10:06 UTC
Cross-Origin-Embedder-Policy Header Missing or Invalid	Open	http://juice:3000/	Unassigned	07 Oct 2026 10:06 UTC

Findings register

#	Title	Severity	Status	Endpoint	CWE	Source Tool	Last Detected
1	Cross-Domain Misconfiguration	Medium	Open	http://juice:3000/styles.css	CWE-264	OWASP ZAP	07 Oct 2026 10:06 UTC
2	Cross-Domain Misconfiguration	Medium	Open	http://juice:3000/sitemap.xml	CWE-264	OWASP ZAP	07 Oct 2026 10:06 UTC
3	Cross-Domain Misconfiguration	Medium	Open	http://juice:3000/robots.txt	CWE-264	OWASP ZAP	07 Oct 2026

#	Title	Severity	Status	Endpoint	CWE	Source Tool	Last Detected
							10:06 UTC
4	Cross-Domain Misconfiguration	Medium	Open	http://juice:3000/assets/public/favicon_js.ico	CWE-264	OWASP ZAP	07 Oct 2026 10:06 UTC
5	Cross-Domain Misconfiguration	Medium	Open	http://juice:3000/	CWE-264	OWASP ZAP	07 Oct 2026 10:06 UTC
6	Content Security Policy (CSP) Header Not Set	Medium	Open	http://juice:3000/sitemap.xml	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
7	Content Security Policy (CSP) Header Not Set	Medium	Open	http://juice:3000/ftp/package.json.bak	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
8	Content Security Policy (CSP) Header Not Set	Medium	Open	http://juice:3000/ftp	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
9	Content Security Policy (CSP) Header Not Set	Medium	Open	http://juice:3000/	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
10	Timestamp Disclosure - Unix	Low	Open	http://juice:3000/styles.css	CWE-497	OWASP ZAP	07 Oct 2026 10:06 UTC
11	Timestamp Disclosure - Unix	Low	Open	http://juice:3000/sitemap.xml	CWE-497	OWASP ZAP	07 Oct 2026 10:06 UTC
12	Timestamp Disclosure - Unix	Low	Open	http://juice:3000/	CWE-497	OWASP ZAP	07 Oct 2026 10:06 UTC
13	Deprecated Feature Policy Header Set	Low	Open	http://juice:3000/sitemap.xml	CWE-16	OWASP ZAP	07 Oct 2026 10:06 UTC
14	Deprecated Feature Policy Header Set	Low	Open	http://juice:3000/scripts.js	CWE-16	OWASP ZAP	07 Oct 2026 10:06 UTC

#	Title	Severity	Status	Endpoint	CWE	Source Tool	Last Detected
15	Deprecated Feature Policy Header Set	Low	Open	http://juice:3000/polyfills.js	CWE-16	OWASP ZAP	07 Oct 2026 10:06 UTC
16	Deprecated Feature Policy Header Set	Low	Open	http://juice:3000/main.js	CWE-16	OWASP ZAP	07 Oct 2026 10:06 UTC
17	Deprecated Feature Policy Header Set	Low	Open	http://juice:3000/	CWE-16	OWASP ZAP	07 Oct 2026 10:06 UTC
18	Dangerous JS Functions	Low	Open	http://juice:3000/main.js	CWE-749	OWASP ZAP	07 Oct 2026 10:06 UTC
19	Cross-Origin-Opener-Policy Header Missing or Invalid	Low	Open	http://juice:3000/sitemap.xml	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
20	Cross-Origin-Opener-Policy Header Missing or Invalid	Low	Open	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
21	Cross-Origin-Opener-Policy Header Missing or Invalid	Low	Open	http://juice:3000/ftp	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
22	Cross-Origin-Opener-Policy Header Missing or Invalid	Low	Open	http://juice:3000/	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
23	Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	Open	http://juice:3000/sitemap.xml	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
24	Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	Open	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
25	Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	Open	http://juice:3000/ftp	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC

#	Title	Severity	Status	Endpoint	CWE	Source Tool	Last Detected
26	Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	Open	http://juice:3000/	CWE-693	OWASP ZAP	07 Oct 2026 10:06 UTC
27	Storable but Non-Cacheable Content	Informational	Open	http://juice:3000/styles.css	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
28	Storable but Non-Cacheable Content	Informational	Open	http://juice:3000/sitemap.xml	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
29	Storable but Non-Cacheable Content	Informational	Open	http://juice:3000/polyfills.js	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
30	Storable but Non-Cacheable Content	Informational	Open	http://juice:3000/assets/public/favicon_js.ico	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
31	Storable but Non-Cacheable Content	Informational	Open	http://juice:3000/	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
32	Storable and Cacheable Content	Informational	Open	http://juice:3000/robots.txt	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
33	Storable and Cacheable Content	Informational	Open	http://juice:3000/ftp	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
34	Non-Storable Content	Informational	Open	http://juice:3000/ftp/package-lock.json.bak	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
35	Non-Storable Content	Informational	Open	http://juice:3000/ftp/encrypt.pyc	CWE-524	OWASP ZAP	07 Oct 2026 10:06 UTC
36	Modern Web Application	Informational	Open	http://juice:3000/sitemap.xml		OWASP ZAP	07 Oct 2026 10:06 UTC

#	Title	Severity	Status	Endpoint	CWE	Source Tool	Last Detected
37	Modern Web Application	Informational	Open	http://juice:3000/juice-shop/build/routes/styles.css		OWASP ZAP	07 Oct 2026 10:06 UTC
38	Modern Web Application	Informational	Open	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18		OWASP ZAP	07 Oct 2026 10:06 UTC
39	Modern Web Application	Informational	Open	http://juice:3000/		OWASP ZAP	07 Oct 2026 10:06 UTC
40	HTTP Missing Security Headers: cross-origin-resource-policy	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
41	HTTP Missing Security Headers: cross-origin-opener-policy	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
42	HTTP Missing Security Headers: cross-origin-embedder-policy	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
43	HTTP Missing Security Headers: referrer-policy	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
44	HTTP Missing Security Headers: x-permitted-cross-domain-policies	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
45	HTTP Missing Security Headers: permissions-policy	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
46	HTTP Missing Security Headers: content-security-policy	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC

#	Title	Severity	Status	Endpoint	CWE	Source Tool	Last Detected
47	HTTP Missing Security Headers: strict-transport-security	Informational	Open	http://juice:3000/	CWE-693	Nuclei	07 Oct 2026 10:05 UTC
48	Public Swagger API - Detect	Informational	Open	http://juice:3000/api-docs/swagger.yaml	CWE-200	Nuclei	07 Oct 2026 10:05 UTC

Detailed findings

1. Cross-Domain Misconfiguration

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10098
Affected URL	http://juice:3000/styles.css
Endpoint	http://juice:3000/styles.css
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-264 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

IMPACT

Not Provided

EVIDENCE

```
Access-Control-Allow-Origin: *
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

REFERENCES

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

2. Cross-Domain Misconfiguration

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10098
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-264 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

IMPACT

Not Provided

EVIDENCE

```
Access-Control-Allow-Origin: *
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

REFERENCES

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

3. Cross-Domain Misconfiguration

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10098
Affected URL	http://juice:3000/robots.txt
Endpoint	http://juice:3000/robots.txt
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-264 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

IMPACT

Not Provided

EVIDENCE

```
Access-Control-Allow-Origin: *
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

REFERENCES

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

4. Cross-Domain Misconfiguration

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10098
Affected URL	http://juice:3000/assets/public/favicon_js.ico
Endpoint	http://juice:3000/assets/public/favicon_js.ico
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-264 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

IMPACT

Not Provided

EVIDENCE

```
Access-Control-Allow-Origin: *
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

REFERENCES

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

5. Cross-Domain Misconfiguration

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10098
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-264 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

IMPACT

Not Provided

EVIDENCE

```
Access-Control-Allow-Origin: *
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

REFERENCES

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

6. Content Security Policy (CSP) Header Not Set

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10038
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/

7. Content Security Policy (CSP) Header Not Set

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10038
Affected URL	http://juice:3000/ftp/package.json.bak
Endpoint	http://juice:3000/ftp/package.json.bak
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/

8. Content Security Policy (CSP) Header Not Set

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10038
Affected URL	http://juice:3000/ftp
Endpoint	http://juice:3000/ftp
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/

9. Content Security Policy (CSP) Header Not Set

Severity	Medium (report: Medium)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10038
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 2 observation(s)

DESCRIPTION

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/

10. Timestamp Disclosure - Unix

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10096
Affected URL	http://juice:3000/styles.css
Endpoint	http://juice:3000/styles.css
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-497 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

A timestamp was disclosed by the application/web server. - Unix

IMPACT

Not Provided

EVIDENCE

```
1528301887
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

REFERENCES

https://cwe.mitre.org/data/definitions/200.html

11. Timestamp Disclosure - Unix

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10096
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-497 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 2 observation(s)

DESCRIPTION

A timestamp was disclosed by the application/web server. - Unix

IMPACT

Not Provided

EVIDENCE

```
1666666667
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

REFERENCES

https://cwe.mitre.org/data/definitions/200.html

12. Timestamp Disclosure - Unix

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10096
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-497 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 2 observation(s)

DESCRIPTION

A timestamp was disclosed by the application/web server. - Unix

IMPACT

Not Provided

EVIDENCE

```
1666666667
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

REFERENCES

https://cwe.mitre.org/data/definitions/200.html

13. Deprecated Feature Policy Header Set

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10063
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-16 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The header has now been renamed to Permissions-Policy.

IMPACT

Not Provided

EVIDENCE

```
Feature-Policy
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy
https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/

14. Deprecated Feature Policy Header Set

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10063
Affected URL	http://juice:3000/scripts.js
Endpoint	http://juice:3000/scripts.js
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-16 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The header has now been renamed to Permissions-Policy.

IMPACT

Not Provided

EVIDENCE

```
Feature-Policy
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy
https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/

15. Deprecated Feature Policy Header Set

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10063
Affected URL	http://juice:3000/polyfills.js
Endpoint	http://juice:3000/polyfills.js
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-16 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The header has now been renamed to Permissions-Policy.

IMPACT

Not Provided

EVIDENCE

```
Feature-Policy
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy
https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/

16. Deprecated Feature Policy Header Set

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10063
Affected URL	http://juice:3000/main.js
Endpoint	http://juice:3000/main.js
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-16 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The header has now been renamed to Permissions-Policy.

IMPACT

Not Provided

EVIDENCE

```
Feature-Policy
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy
https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/

17. Deprecated Feature Policy Header Set

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10063
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-16 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The header has now been renamed to Permissions-Policy.

IMPACT

Not Provided

EVIDENCE

```
Feature-Policy
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy
https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/

18. Dangerous JS Functions

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10110
Affected URL	http://juice:3000/main.js
Endpoint	http://juice:3000/main.js
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-749 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

A dangerous JS function seems to be in use that would leave the site vulnerable.

IMPACT

Not Provided

EVIDENCE

```
bypassSecurityTrustHtml(
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

See the references for security advice on the use of these functions.

REFERENCES

https://v17.angular.io/guide/security

19. Cross-Origin-Opener-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	Cross-Origin-Opener-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy

20. Cross-Origin-Opener-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18
Endpoint	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18
HTTP method	GET
Parameter	Cross-Origin-Opener-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy

21. Cross-Origin-Opener-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000/ftp
Endpoint	http://juice:3000/ftp
HTTP method	GET
Parameter	Cross-Origin-Opener-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy

22. Cross-Origin-Opener-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	Cross-Origin-Opener-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 2 observation(s)

DESCRIPTION

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy

23. Cross-Origin-Embedder-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	Cross-Origin-Embedder-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

24. Cross-Origin-Embedder-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18
Endpoint	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18
HTTP method	GET
Parameter	Cross-Origin-Embedder-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

25. Cross-Origin-Embedder-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000/ftp
Endpoint	http://juice:3000/ftp
HTTP method	GET
Parameter	Cross-Origin-Embedder-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

26. Cross-Origin-Embedder-Policy Header Missing or Invalid

Severity	Low (report: Low)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 90004
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	Cross-Origin-Embedder-Policy
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 2 observation(s)

DESCRIPTION

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

27. Storable but Non-Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/styles.css
Endpoint	http://juice:3000/styles.css
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

IMPACT

Not Provided

EVIDENCE

```
max-age=0
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231
https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

28. Storable but Non-Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

IMPACT

Not Provided

EVIDENCE

```
max-age=0
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231
https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

29. Storable but Non-Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/polyfills.js
Endpoint	http://juice:3000/polyfills.js
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

IMPACT

Not Provided

EVIDENCE

```
max-age=0
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231
https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

30. Storable but Non-Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/assets/public/favicon_js.ico
Endpoint	http://juice:3000/assets/public/favicon_js.ico
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

IMPACT

Not Provided

EVIDENCE

```
max-age=0
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231
https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

31. Storable but Non-Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

IMPACT

Not Provided

EVIDENCE

```
max-age=0
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231
https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

32. Storable and Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/robots.txt
Endpoint	http://juice:3000/robots.txt
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

33. Storable and Cacheable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/ftp
Endpoint	http://juice:3000/ftp
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

34. Non-Storable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/ftp/package-lock.json.bak
Endpoint	http://juice:3000/ftp/package-lock.json.bak
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.

IMPACT

Not Provided

EVIDENCE

```
403
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

35. Non-Storable Content

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10049
Affected URL	http://juice:3000/ftp/encrypt.pyc
Endpoint	http://juice:3000/ftp/encrypt.pyc
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-524 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.

IMPACT

Not Provided

EVIDENCE

```
403
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).

REFERENCES

https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

36. Modern Web Application

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10109
Affected URL	http://juice:3000/sitemap.xml
Endpoint	http://juice:3000/sitemap.xml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	*Not Provided* · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

IMPACT

Not Provided

EVIDENCE

```
<script>
    window.addEventListener("load", function(){
      window.cookieconsent.initialise({
        "palette": {
          "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
          "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
        },
        "theme": "classic",
        "position": "bottom-right",
        "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking
experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?
v=9PnbKL3wuH4" }
      })});
  </script>
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

This is an informational alert and so no changes are required.

REFERENCES

Not Provided

37. Modern Web Application

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10109
Affected URL	http://juice:3000/juice-shop/build/routes/styles.css
Endpoint	http://juice:3000/juice-shop/build/routes/styles.css
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	*Not Provided* · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

IMPACT

Not Provided

EVIDENCE

```
<script>
    window.addEventListener("load", function(){
      window.cookieconsent.initialise({
        "palette": {
          "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
          "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
        },
        "theme": "classic",
        "position": "bottom-right",
        "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking
experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?
v=9PnbKL3wuH4" }
      })});
  </script>
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

This is an informational alert and so no changes are required.

REFERENCES

Not Provided

38. Modern Web Application

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10109
Affected URL	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18
Endpoint	http://juice:3000/juice-shop/build/routes/fileServer.js:68:18
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	*Not Provided* · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 1 observation(s)

DESCRIPTION

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

IMPACT

Not Provided

EVIDENCE

```
<script>
    window.addEventListener("load", function(){
      window.cookieconsent.initialise({
        "palette": {
          "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
          "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
        },
        "theme": "classic",
        "position": "bottom-right",
        "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking
experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?
v=9PnbKL3wuH4" }
      })});
  </script>
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

This is an informational alert and so no changes are required.

REFERENCES

Not Provided

39. Modern Web Application

Severity	Informational (report: Informational)
Status	Open
Assigned to	Unassigned
Source	OWASP ZAP · 10109
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	*Not Provided* · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:06 UTC, last 07 Oct 2026 10:06 UTC, 2 observation(s)

DESCRIPTION

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

IMPACT

Not Provided

EVIDENCE

```
<script>
    window.addEventListener("load", function(){
      window.cookieconsent.initialise({
        "palette": {
          "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
          "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
        },
        "theme": "classic",
        "position": "bottom-right",
        "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking
experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?
v=9PnbKL3wuH4" }
      })});
  </script>
```

STEPS TO REPRODUCE

Not Provided

ORIGINAL RECOMMENDATION (FROM THE REPORT)

This is an informational alert and so no changes are required.

REFERENCES

Not Provided

40. HTTP Missing Security Headers: cross-origin-resource-policy

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

41. HTTP Missing Security Headers: cross-origin-opener-policy

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

42. HTTP Missing Security Headers: cross-origin-embedder-policy

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

43. HTTP Missing Security Headers: referrer-policy

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

44. HTTP Missing Security Headers: x-permitted-cross-domain-policies

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

45. HTTP Missing Security Headers: permissions-policy

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

46. HTTP Missing Security Headers: content-security-policy

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

47. HTTP Missing Security Headers: strict-transport-security

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · http-missing-security-headers
Affected URL	http://juice:3000
Endpoint	http://juice:3000/
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-693 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: */*' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 13.2) AppleWebKit/619.14.1 (KHTML, like Gecko) Version/17.7.52 Safari/619.14.1' 'http://juice:3000'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

Not Provided

48. Public Swagger API - Detect

Severity	Informational (report: info)
Status	Open
Assigned to	Unassigned
Source	Nuclei · swagger-api
Affected URL	http://juice:3000/api-docs/swagger.yaml
Endpoint	http://juice:3000/api-docs/swagger.yaml
HTTP method	GET
Parameter	*Not Provided*
CWE / OWASP / CVSS	CWE-200 · *Not Provided* · *Not Provided*
Detected	first 07 Oct 2026 10:05 UTC, last 07 Oct 2026 10:05 UTC, 1 observation(s)

DESCRIPTION

Public Swagger API was detected.

IMPACT

Not Provided

EVIDENCE

Not Provided

STEPS TO REPRODUCE

```
curl -X 'GET' -d '' -H 'Accept: text/html, application/json' -H 'Accept-Language: en' -H 'User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:127.0) Gecko/20100101 Firefox/127.0' 'http://juice:3000/api-docs/swagger.yaml'
```

ORIGINAL RECOMMENDATION (FROM THE REPORT)

Not Provided

REFERENCES

https://swagger.io/

Remediation summary

Needs action	48 (Open 48, In Progress 0, Reopened 0)
Fixed	0 (Resolved 0, Closed 0)
Exceptions	0 (Accepted Risk 0, False Positive 0)
Active and unassigned	48
Resolved or closed in the last 30 days	0

Active findings by assignee

Assignee	Active findings
No active findings are assigned.	

Recommendations above are the scanners' own text. No additional remediation guidance has been added.

Scan information

Scan	Tool / format	Scan date	Uploaded	Processing	Findings	Original file
zap-baseline.json	OWASP ZAP JSON	07 Oct 2026 10:06 UTC	07 Oct 2026 14:23 UTC	Completed	39	zap-baseline.json
nuclei.jsonl	Nuclei JSONL	07 Oct 2026 10:05 UTC	07 Oct 2026 14:23 UTC	Completed	9	nuclei.jsonl